ICare After-Fix ZAP Passive Assessment

Group 113. Isolated synthetic fixtures only. Passive scan and targeted manual HTTP verification. No spider or active scan.

Site: http://host.docker.internal:4021

Generated on Fri, 16 Oct 2026 11:09:47

ZAP Version: 2.17.0

ZAP by Checkmarx

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	3
Low	3
Informational	1
False Positives:	0

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	1
Low	Warning		ZAP warnings logged - see the zap.log file for details	2
Info	Informational		Percentage of network failures	24 %
Info	Informational	http://127.0.0.1:8091	Percentage of endpoints with content type text/plain	100 %
Info	Informational		Percentage of endpoints	100 %

		http://127.0.0.1:8091	with method GET	
Info	Informational	http://127.0.0.1:8091	Count of total endpoints	1
Info	Informational	http://host.docker.internal:4021	Percentage of responses with status code 2xx	35 %
Info	Informational	http://host.docker.internal:4021	Percentage of responses with status code 4xx	60 %
Info	Informational	http://host.docker.internal:4021	Percentage of responses with status code 5xx	3 %
Info	Informational	http://host.docker.internal:4021	Percentage of endpoints with content type application/json	90 %
Info	Informational	http://host.docker.internal:4021	Percentage of endpoints with content type text/html	9 %
Info	Informational	http://host.docker.internal:4021	Percentage of endpoints with method GET	39 %
Info	Informational	http://host.docker.internal:4021	Percentage of endpoints with method POST	36 %
Info	Informational	http://host.docker.internal:4021	Percentage of endpoints with method PUT	24 %
Info	Informational	http://host.docker.internal:4021	Count of total endpoints	33
Info	Informational	http://host.docker.internal:4021	Percentage of slow responses	7 %

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	3
Missing Anti-clickjacking Header	Medium	3
Sub Resource Integrity Attribute Missing	Medium	3
Application Error Disclosure	Low	2
Information Disclosure - Debug Error Messages	Low	1
X-Content-Type-Options Header Missing	Low	Systemic
Modern Web Application	Informational	3

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://host.docker.internal:4021/
Node Name	http://host.docker.internal:4021/
Method	GET
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:4021/signin
Node Name	http://host.docker.internal:4021/signin
Method	GET
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:4021/signup
Node Name	http://host.docker.internal:4021/signup
Method	GET
Attack	
Evidence	
Other Info	

Instances	3
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	**Missing Anti-clickjacking Header**
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://host.docker.internal:4021/
Node Name	http://host.docker.internal:4021/
Method	GET
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:4021/signin
Node Name	http://host.docker.internal:4021/signin
Method	GET
Attack	
Evidence	
Other Info	
URL	http://host.docker.internal:4021/signup
Node Name	http://host.docker.internal:4021/signup
Method	GET
Attack	
Evidence	
Other Info	
Instances	3
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.

Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium	**Sub Resource Integrity Attribute Missing**
Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	http://host.docker.internal:4021/
Node Name	http://host.docker.internal:4021/
Method	GET
Attack	
Evidence	<link rel="stylesheet" href="https://cdn.jsdelivr.net/npm/@fortawesome/fontawesome-free@5.15.4/css/all.min.css"/>
Other Info	
URL	http://host.docker.internal:4021/signin
Node Name	http://host.docker.internal:4021/signin
Method	GET
Attack	
Evidence	<link rel="stylesheet" href="https://cdn.jsdelivr.net/npm/@fortawesome/fontawesome-free@5.15.4/css/all.min.css"/>
Other Info	
URL	http://host.docker.internal:4021/signup
Node Name	http://host.docker.internal:4021/signup
Method	GET
Attack	
Evidence	<link rel="stylesheet" href="https://cdn.jsdelivr.net/npm/@fortawesome/fontawesome-free@5.15.4/css/all.min.css"/>
Other Info	
Instances	3
Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Low	**Application Error Disclosure**
Description	This page contains an error/warning message that may disclose sensitive information like the location of the file that produced the unhandled exception. This information can be used to launch further attacks against the web application. The alert could be a false positive if the error message is found inside a documentation page.
URL	http://host.docker.internal:4021/api/users/signin

Node Name	http://host.docker.internal:4021/api/users/signin ()({malformed)
Method	POST
Attack	
Evidence	HTTP/1.1 500 Internal Server Error
Other Info	
URL	http://host.docker.internal:4021/api/prescriptions/6ad2054fb576e6fe1ae979fc
Node Name	http://host.docker.internal:4021/api/prescriptions/6ad2054fb576e6fe1ae979fc ()({patientName:{synthetic}})
Method	PUT
Attack	
Evidence	HTTP/1.1 500 Internal Server Error
Other Info	
Instances	2
Solution	Review the source code of this page. Implement custom error pages. Consider implementing a mechanism to provide a unique error reference/identifier to the client (browser) while logging the details on the server side and not exposing them to the user.
Reference	
CWE Id	550
WASC Id	13
Plugin Id	90022

Low	**Information Disclosure - Debug Error Messages**
Description	The response appeared to contain common error messages returned by platforms such as ASP.NET, and Web-servers such as IIS and Apache. You can configure the list of common debug messages.
URL	http://host.docker.internal:4021/api/users/signin
Node Name	http://host.docker.internal:4021/api/users/signin ()({malformed)
Method	POST
Attack	
Evidence	Internal server error
Other Info	
Instances	1
Solution	Disable debugging messages before pushing to production.
Reference	
CWE Id	1295
WASC Id	13
Plugin Id	10023

Low	**X-Content-Type-Options Header Missing**
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of

	Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://host.docker.internal:4021/api/orders/6ad2054fb576e6fe1ae979f2
Node Name	http://host.docker.internal:4021/api/orders/6ad2054fb576e6fe1ae979f2
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:4021/api/orders
Node Name	http://host.docker.internal:4021/api/orders ()({user,orderItems:[{_id,quantity,price}], shippingAddress:{fullName,address,city,postalCode,country},paymentMethod,itemsPrice, shippingPrice,taxPrice,totalPrice})
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:4021/api/orders
Node Name	http://host.docker.internal:4021/api/orders ()({user,orderItems:[{_id,quantity}], shippingAddress:{fullName,address,city,postalCode,country},paymentMethod,itemsPrice, shippingPrice,taxPrice,totalPrice})
Method	POST
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:4021/api/orders/6ad2054fb576e6fe1ae979f2/deliver
Node Name	http://host.docker.internal:4021/api/orders/6ad2054fb576e6fe1ae979f2/deliver ()({})
Method	PUT
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://host.docker.internal:4021/api/orders/6ad2054fb576e6fe1ae979f2/pay
Node Name	http://host.docker.internal:4021/api/orders/6ad2054fb576e6fe1ae979f2/pay ()({})

Method	PUT
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	**Modern Web Application**
Description	The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one.
URL	http://host.docker.internal:4021/
Node Name	http://host.docker.internal:4021/
Method	GET
Attack	
Evidence	<script defer="defer" src="/static/js/main.115cc07d.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://host.docker.internal:4021/signin
Node Name	http://host.docker.internal:4021/signin
Method	GET
Attack	
Evidence	<script defer="defer" src="/static/js/main.115cc07d.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://host.docker.internal:4021/signup
Node Name	http://host.docker.internal:4021/signup
Method	GET
Attack	
Evidence	<script defer="defer" src="/static/js/main.115cc07d.js"></script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.

Instances	3
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109